

《信息系统安全》第三讲

安全需求及安全策略

2024年10月8日

周亚建

yajian@bupt.edu.cn

Overview of Last Class

信息系统为什么会面临安全问题

内因

硬件缺陷

软件缺陷

协议缺陷

外因

人为攻击
(攻击致命度)

自然灾害

攻防不对称性



系统连续可靠正常地运行，
信息服务不中断

技术

管理

人员

工程

机密性

完整性

可用性

基于保障的信息安全模型

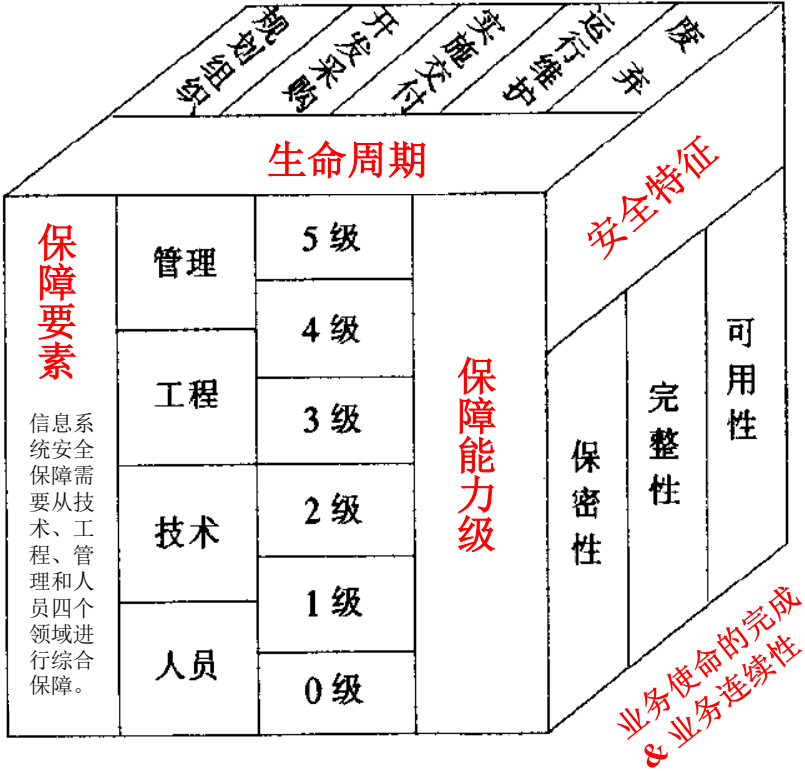
IBM SOA

可信计算

等级保护2.0
“6.2 云计算安全扩展要求”

信息安全的安全架构

Overview of Last Class



DSMM（Data Security capability Maturity Model）

DSMM认证是我国首个依据国家标准《信息安全技术 数据安全能力成熟度模型》（GB/T 37988-2019）、《数据安全能力建设实施指南v1.0》开展的数据安全认证，该标准是由阿里巴巴联合中国电子技术标准化研究院、国家信息安全工程技术研究中心、中国信息安全测评中心等业内权威机构联合编写的国家标准，是国内第一个数据安全标准认证，于2019年8月30日发布，2020年3月1日正式实施。

DSMM标准能够用来衡量一个组织的数据安全能力成熟度水平，可以帮助行业、企业和组织发现数据安全能力短板，相关主管部门也可以用于数据安全能力管理，根据数据安全能力水平高低决定企业拥有数据的类型和范围，最终提升全社会的数据安全水平和行业竞争力，确保大数据产业及数字经济的发展。

DSMM评估以组织为单位，以数据为中心，围绕四个安全能力维度、七个安全过程维度、五个安全能力等级评价组织的数据安全能力。



Overview of Last Class

安全 = 及时的检测和处理 $P_t > Dt + R_t$

信息网络的硬件、软件及其系统中的数据受到保护，不受偶然的或者恶意的原因而遭到破坏、更改、泄露，系统连续可靠正常地运行，信息服务不中断。

信息系统安全保障是在信息系统的**整个生命周期**中，通过对信息系统的**风险分析**，制定并执行相应的安全保障策略，从**技术、管理、工程和人员**等方面提出安全保障要求，确保信息系统的**保密性、完整性和可用性**，降低安全风险到可接受的程度，从而保障系统实现**组织机构的使命**。

本次课程的任务

开发一个信息系统，在项目启动阶段，从安全角度有哪些问题需要明确？



- 系统面临哪些威胁
- 系统的安全目标是什么
- 系统应该提供什么样的安全服务
- 工作将受哪些条件约束

.....

安全需求和安全策略

启动阶段的目标

- 根据业务流程、系统功能、目标用户、工作环境等，定义系统的需求
- 明确约束条件，包括场地、设备、经费、人员等
- 起草一份针对系统的安全策略
 - 这是这一阶段必不可少的部分，是构建一个可信系统的基础

在项目启动阶段进行安全设计，而不是在实现或维护阶段

- 后来加上的服务包和补丁会带来新的漏洞
- 容易陷入补丁、修复、再补丁的恶性循环

安全
需求



安全
策略

什么是安全需求？

确定信息系统需要保护的對象及其原因，在“知己知彼”的前提下实现有针对性地选择、部署和实施安全策略

安全需求的定义

安全需求

就是在设计一个安全系统时期望得到的安全保障

不同的用户、不同的行业、不同的地点以及不同的社会制度有不同的安全需求

个人隐私、商业机密、军事安全、防假冒、防篡改、可审计等

举例：电子交易中的安全需求

目的：保证电子交易的安全



交易双方身份的确定性需求

- 电子交易的双方，可能素昧平生、相隔千里
- 要能确认对方的身份
客户端是否是一个骗子？商店是否黑店？

因此，电子交易的前提是能方便、可靠地确认对方身份



信息的不可伪造性需求

- 电子交易中，交易双方的文件必须是不可伪造的，否则将损害某一方的利益
- 这也是不可抵赖性的前提

安全需求

信息的完整性需求



- 输入时可能会发生意外差错，或者故意欺诈
- 传输时可能会发生信息丢失、重复或者发生次序差异

因此，电子交易的基础是保持交易双方的信息完整性

信息的不可抵赖性需求



- 交易一旦达成，是不能被抵赖的，否则也将损害某一方的利益
- 交易过程中，各个环节都必须是不可抵赖的

一般性的安全需求

机密性需求，防止信息被泄漏给未授权的用户

自主安全策略、强制安全策略；需知原则

完整性需求，防止未授权用户对信息的修改

维护系统资源在一个有效的、预期的状态，防止资源被不正确、不适当的修改；维护系统不同部分的一致性；防止在涉及记账或审计的事件中“舞弊”行为的发生。

可用性需求，保证授权用户对系统信息的可访问性

“授权用户的任何正确的输入，系统会有相应的正确的输出”

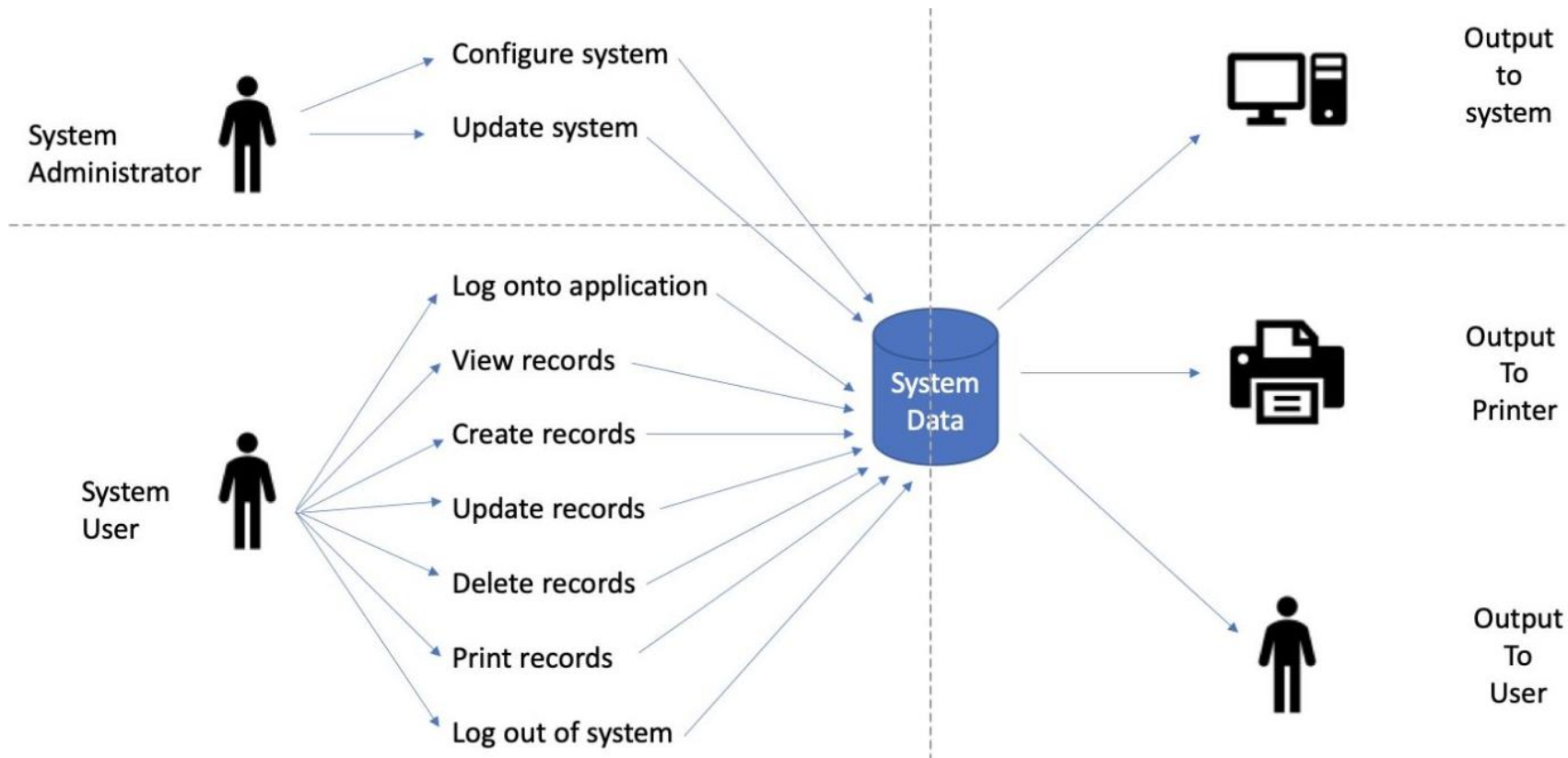
可记账性需求，防止用户对访问过某信息或执行过某一操作以否认

可对发生的事件、操作等进行回溯

安全需求的例子

例子	机密性	完整性	可记账性	可用性
军事安全策略	侧重			
商用安全策略		侧重	侧重	
电信部门				侧重

安全需求分析的例子

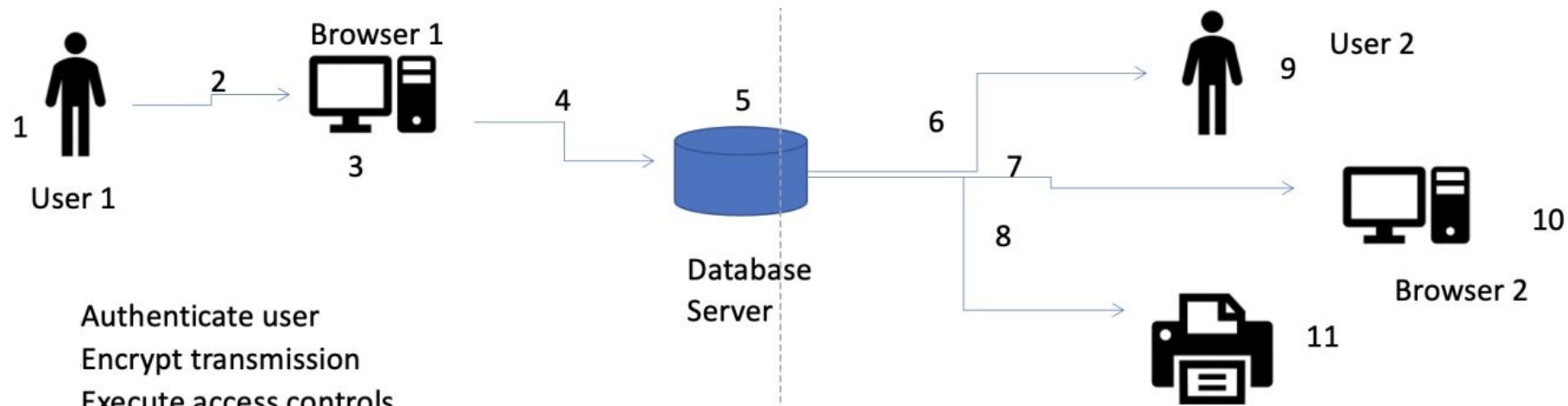


系统用户需要log onto application, 查看/创建/更新/删除/打印记录, 然后log out

用户需求/用户的安全需求/用户需求的替代方案及风险

User Needs	User Security Needs	User Needs Alternatives
Log onto application	Log onto application applying access controls	Log into a front end authentication server; risk is single point of compromise
View records	Enforce appropriate privilege to view records	Log in with role based access control; risk is aggregation of access privilege
Create records	Enforce appropriate privilege to create records	Log in with role based access control; risk is aggregation of access privilege
Update records	Enforce appropriate privilege to update records	Log in with role based access control; risk is aggregation of access privilege
Delete records	Enforce appropriate privilege to delete records	Log in with role based access control; risk is aggregation of access privilege
Print records	Enforce appropriate privilege to print records	Log in with role based access control; risk is aggregation of access privilege

映射安全功能



- Authenticate user
- Encrypt transmission
- Execute access controls
- Encrypt transmission
- Encrypt data at rest
- Encrypt transmission
- Encrypt transmission
- Encrypt transmission
- Authenticate end user
- Authenticate end system
- Authenticate end printer

Printer

映射需求

Security Requirement	Security Requirement Description	Preliminary Security Requirement Test
Access Enforcement	The system enforces approved authorizations for logical access to information and system resources in accordance with applicable access control policies.	Determine if the system enforces approved authorizations for logical access to information and system resources in accordance with applicable access control policies.
Information Flow Enforcement	The system enforces approved authorizations for controlling the flow of information within the system and between interconnected systems based on information flow control policies.	Determine if the system enforces approved authorizations for controlling the flow of information within the system and between interconnected systems based on organization-defined information flow control policies.
Unsuccessful Logon Attempts	The system enforces a limit of consecutive invalid logon attempts by a user and automatically locks the account after three consecutive unsuccessful tries.	Determine if the system enforces a limit of organization-defined number of consecutive invalid logon attempts by a user during an organization-defined time period.
Session Termination	The system automatically terminates a user session after one hour of inactivity.	Determine if the system automatically terminates a user session after organization-defined conditions or trigger events requiring session disconnect occurs.
Content of Audit Records	The system provides centralized management and configuration of the content to be captured in audit records generated by the system.	Determine if the organization defines information system components that generate audit records whose content is to be centrally managed and configured by the information system.
Least Functionality	The system to provide only essential capabilities for the performance of user function. The system to provide only essential capabilities for the performance of user function.	Determine if the system is configured to provide only essential capabilities.
Identification and Authentication	The system uniquely identifies and authenticates organizational users.	Determine if the information system uniquely identifies and authenticates organizational users.
Identification and Authentication to Privileged Accounts	The system implements multifactor authentication for network access to privileged accounts.	Determine if the system implements multifactor authentication for network access to privileged accounts.
Identification and Authentication to Non-Privileged Accounts	The system implements multifactor authentication for network access to non-privileged accounts.	Determine if the system implements multifactor authentication for network access to non-privileged accounts.
Device Identification and Authentication	The system uniquely identifies and authenticates all devices before establishing a connection.	Determine if the system uniquely identifies and authenticates all devices before establishing a connection.

什么是安全策略？

确定保护的对象是什么，要防范的对象是什么，在
安全防范上能投入多少，

安全策略



针对面临的威胁决定采用何种对策的方法

信息安全策略提供：信息系统保护的内容和目标，信息保护的职责落实，实施信息保护的方法，事故的处理等。



一个信息系统是“安全系统”，指的是该系统达到当初设计时所制定的安全策略的要求

安全策略的重要性

自董卓造逆，豪杰并起。曹操势不及袁绍，而能克绍者，天时与人谋也。今操已拥兵百万，挟天子以令诸侯，此诚不可与争锋。江东孙权已历三世，国险而民附，此可用为援而不可图也。荆州北据汉、沔，利尽南海，东连吴会，西通巴、蜀，此用武之地，非其主不能守；是殆天所以资将军，益州险塞，沃野千里，天府之国，高祖因之以成帝业；今刘璋暗弱，民殷国富，而不知存恤，智能之士，思得明君。将军帝室之胄，信义著于四海，总揽英雄，思贤如渴，若跨有荆、益，保其岩阻，西和诸戎，南抚彝、越，外结孙权，内修政理；待天下有变，则命一上将出荆州之兵以向宛、洛，将军率益州之众出秦川，百姓岂有不箪食相迎乎？如是，则大业可成，汉室可兴。此亮为将军所谋者也。将军欲成霸业，北让曹操占天时，南让孙权占地利，将军可占人和。先取荆州，后取西川，以成鼎足之势，然后可图中原也。



“其始误于隆中对，千里之遥而二分兵力。其终则关羽、刘备、诸葛三分兵力，安得不败。”

——毛泽东

“去荆州而就西蜀，吾知其无能为业也。”

——苏洵

三十六计——

三十六计——并战计

三十六计——败战计

混战计

★ 19釜底抽薪

力量上不能
即“以柔克

★ 20混水摸鱼

趁着敌人
见，他随

★ 21金蝉脱壳

为了有效
必须保存
使友军不
注意力，

★ 22关门捉贼

对小股敌
敌人，如
很不利的

★ 23远交近战

地势地形
人是有利
处的敌人
相互猜疑，

★ 24假道伐虢

借道用兵
得的，情
威胁，就
敌人必然
诱惑，利
去，控制
阵地，所

并战计

★ 25偷梁换柱

指的是用偷换的方法，暗中改换事物的本质，以达到蒙骗欺骗的目的，此计用在战争中，时反复变动行军路线，建议调换敌方的兵力，军队有可乘之机时，一举将其全部控制取得

★ 26指桑骂槐

率领不服从自己的去同敌人作战，如果你对士兵并不服从，这时可以故意制造误会，引起生过错，建议暗示警告，即从另一方面诱导使用强硬而果断的手段逼迫士兵服从的方法

★ 27假痴不癫

表面上糊涂实际内心很清楚，假装不行动，暗中策划等待有利时机，一方面能麻痹敌人，而让士兵误以为有神相助，于是士气大增，战争的胜利

★ 28上屋抽梯

指用小的利益引诱敌人上当，然后切断敌人，敌人围住全部歼灭，因为敌人不是那么容易，所以应该是先给敌人安分好“梯子”，也就是小利益，让敌人上当，等敌人“上屋”，也就好的包围圈，然后拆掉“梯子”全部歼灭

★ 29树上开花

指树上本来没有开花，但可以將假花粘在树上冒充真花，取得乱真的效果，因为战场上指挥官很容易被假象所惑，所以善于布置虚张声势；巧布迷魂阵，借别人的局面布成由力弱小的阵容，看起来也会明显强大

★ 30反客为主

为人驱使者为奴，为人尊处者为客，不能以客，能立足者为久客，客久而不能主事者为主事则可渐握机要，而为主矣。故反客为主一步须争客位；第二步须乘隙；第三步须足须握机；第五乃为主。

败战计

★ 31美人计

兵力强大的，就要攻打其将帅，将帅明智的，就打击将帅的心情，将帅斗志衰弱，其部队士气消沉，敌军的气势必定萎缩，利用敌人内部的严重弱点，来控制敌人，可以有把握地保存自己的实力

★ 32空城计

心理战术，是在敌众我寡的情况下，缺乏兵备而故意使敌方以不设兵备，造成敌方错觉，从而惊退敌军之事

★ 33反间计

在疑阵中再布疑阵，利用敌之间谍，行我方反间之计，是送上门的好计策，与我无损；利用间谍，就是使敌人内部互相猜疑，利用反间计就是利用敌人的间谍来离间敌人

★ 34苦肉计

人不自己迫害自己，受迫害必是真的，真的变假，间谍便乘机活动，把他骗得乖乖的、顺着他活动

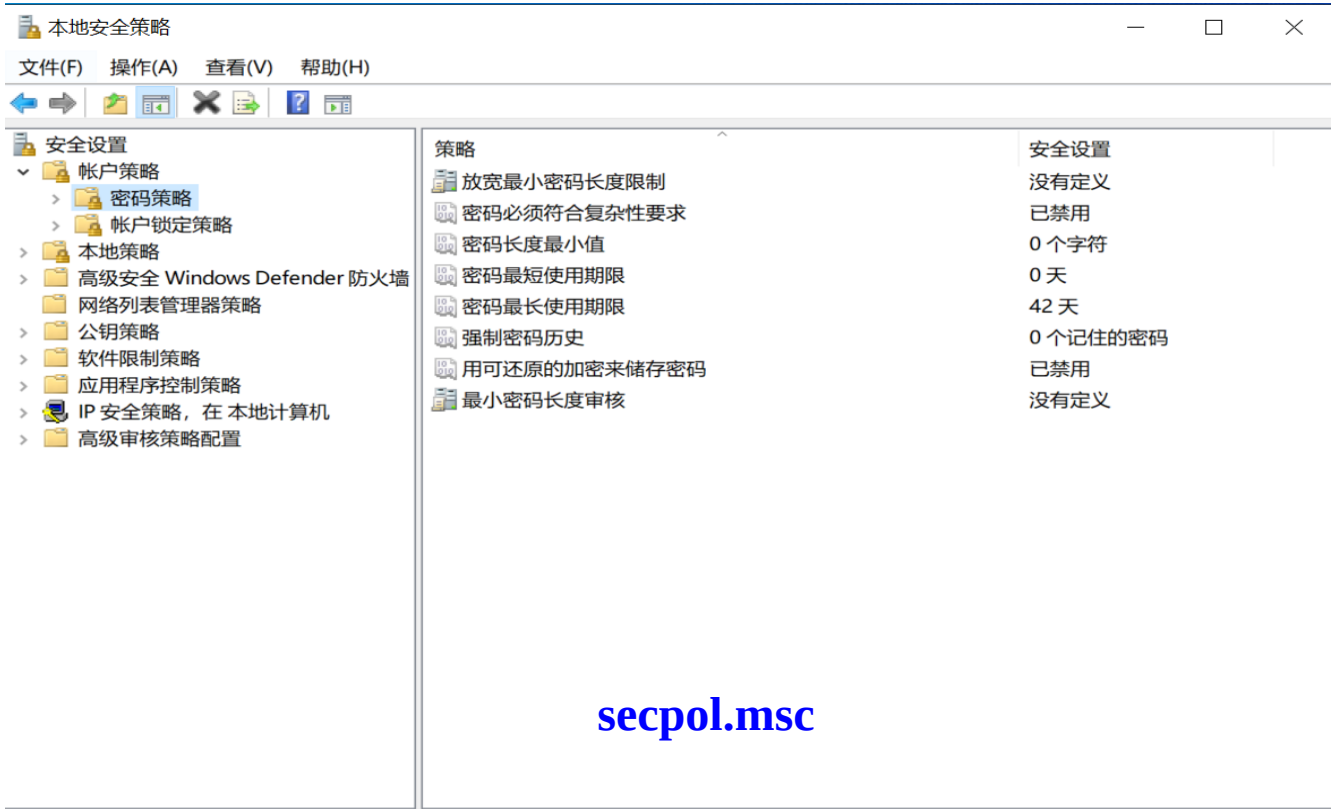
★ 35连环计

多计并用，计计相连，环环相扣，一计累敌，一计攻敌，任何强敌，无攻不破。如果敌方力量强大，就不要硬拼，要用计使其自相钳制，借以削弱敌方的战斗力。巧妙地运用谋略，就如天神相助

★ 36走为上计

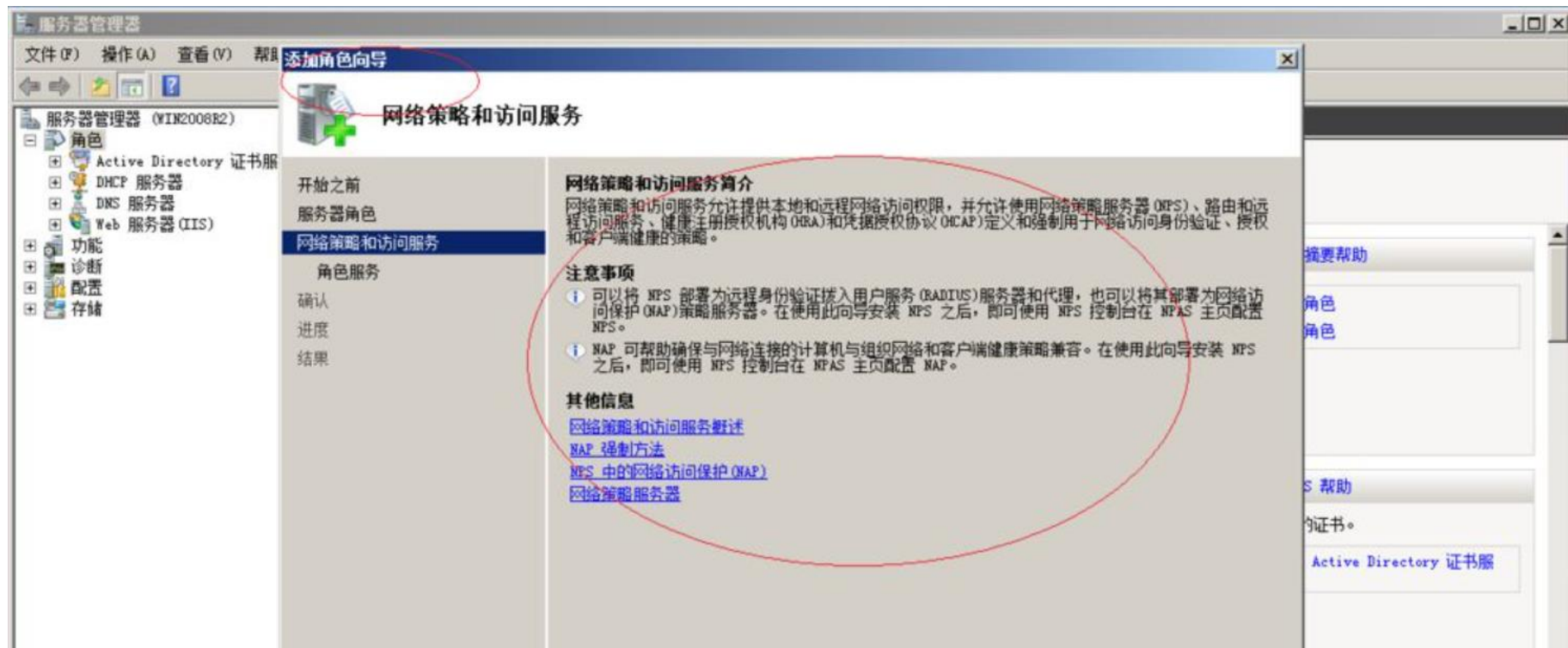
全军退却避开强敌，用退却的办法避开危险，没有过错，并且这事不冒犯用兵的常规

安全策略实例

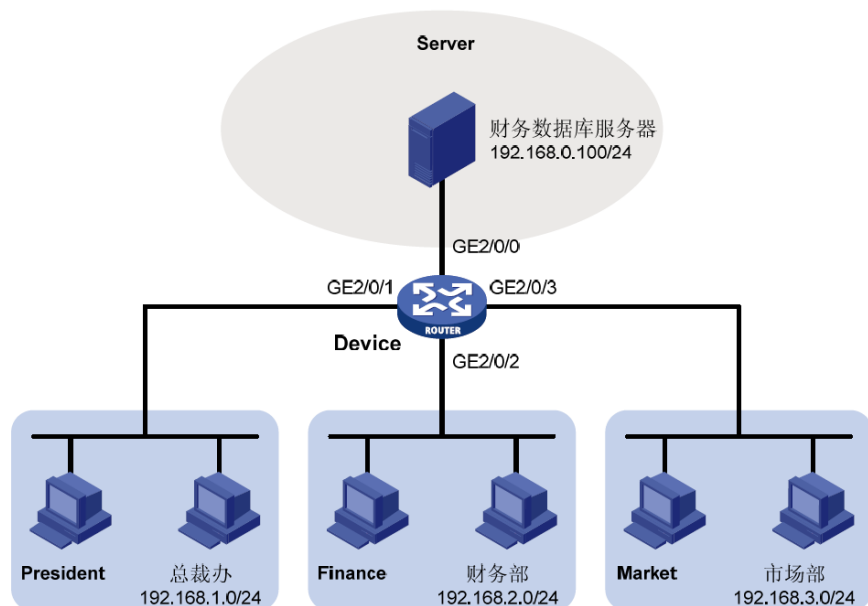


secpol.msc

安全策略实例



安全策略实例



某公司内的各部门之间通过路由器 Device 实现互连，该公司的工作时间为每周工作日的8点到18点。

安全策略要求： 允许总裁办在任意时间、财务部在工作时间访问财务数据库服务器，禁止其它部门在任何时间、财务部在非工作时间访问该服务器。

安全策略配置步骤

创建名为work的时间段，其时间范围为每周工作日的8点到18点。

<Device> system-view

[Device] time-range work 08:00 to 18:00 working-day

创建IPv4 高级ACL 3000，并制订如下规则：允许总裁办在任意时间、财务部在工作时间访问财务数据库服务器，禁止其它部门在任何时间、财务部在非工作时间访问该服务器。

[Device] acl advanced 3000

[Device-acl-ipv4-adv-3000] rule permit ip source 192.168.1.0 0.0.0.255 destination 192.168.0.100 0

[Device-acl-ipv4-adv-3000] rule permit ip source 192.168.2.0 0.0.0.255 destination 192.168.0.100 0 time-range work

[Device-acl-ipv4-adv-3000] rule deny ip source any destination 192.168.0.100 0

[Device-acl-ipv4-adv-3000] quit

安全策略配置步骤

应用IPv4 高级ACL 3000 对接口GigabitEthernet2/0/0 出方向上的报文进行过滤

```
[Device] interface gigabitethernet 2/0/0
```

```
[Device-GigabitEthernet2/0/0] packet-filter 3000 outbound
```

```
[Device-GigabitEthernet2/0/0] quit
```

安全策略的验证

配置完成后，在各部门的PC（假设OS均为Windows 7 Pro）上可以使用ping 命令检验配置效果，在Device 上可以使用display acl 命令查看ACL 的配置和运行情况。

例如在工作时间：

在财务部的PC 上检查到财务数据库服务器是否可达

C:\> ping 192.168.0.100

Pinging 192.168.0.100 with 32 bytes of data:

Reply from 192.168.0.100: bytes=32 time=1ms TTL=255

Reply from 192.168.0.100: bytes=32 time<1ms TTL=255

Reply from 192.168.0.100: bytes=32 time<1ms TTL=255

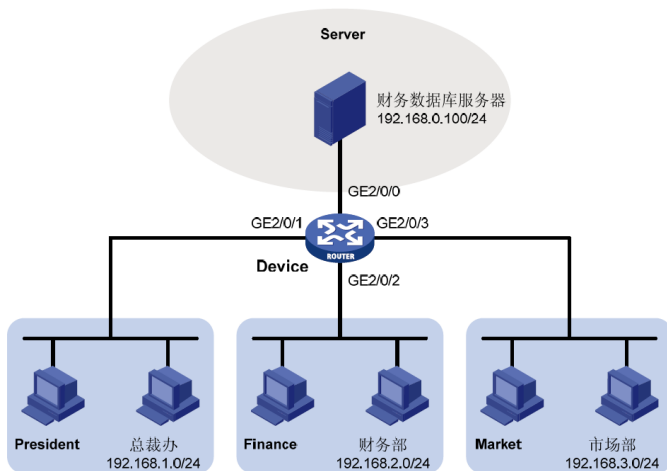
Reply from 192.168.0.100: bytes=32 time<1ms TTL=255

Ping statistics for 192.168.0.100:

Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),

Approximate round trip times in milli-seconds:

Minimum = 0ms, Maximum = 1ms, Average = 0ms



由此可见，财务部的PC
能够在工作时间访问财务
数据库服务器。

安全策略的验证

配置完成后，在各部门的PC（假设OS均为Windows 7 Pro）上可以使用ping 命令检验配置效果，在Device 上可以使用display acl 命令查看ACL 的配置和运行情况。

在市场部的PC 上检查财务数据库服务器是否可达

C:\> ping 192.168.0.100

Pinging 192.168.0.100 with 32 bytes of data:

Request timed out.

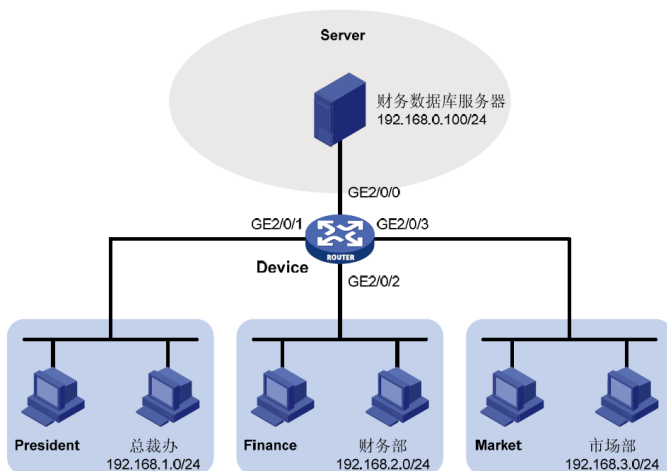
Request timed out.

Request timed out.

Request timed out.

Ping statistics for 192.168.0.100:

Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),



由此可见，市场部的PC 不能在工作时间访问财务数据库服务器。

安全策略的验证

配置完成后，在各部门的PC（假设OS均为Windows 7 Pro）上可以使用ping 命令检验配置效果，在Device 上可以使用display acl 命令查看ACL 的配置和运行情况。

查看IPv4 高级ACL 3000 的配置和运行情况

```
[Device] display acl 3000
```

```
Advanced IPv4 ACL 3000, 3 rules,
```

```
ACL's step is 5
```

```
rule 0 permit ip source 192.168.1.0 0.0.0.255 destination 192.168.0.100 0
```

```
rule 5 permit ip source 192.168.2.0 0.0.0.255 destination 192.168.0.100 0 time-range work  
(Active) (4 times matched)
```

```
rule 10 deny ip destination 192.168.0.100 0 (4 times matched)
```

由此可见，由于目前是工作时间，因此规则5 是生效的；
由于之前使用了ping 命令的缘故，规则5 和规则10 分别被匹配了4 次。

安全策略依据的标准

ISO/IEC 27001: 2013 Information technology — Security techniques — Information security management systems — Requirements

A.5 信息安全策略	<i>A.5 Information security policy</i>
A.5.1 信息安全策略 控制目标：为信息安全提供符合业务需求和相关法律、法规，提供管理方向和支持；	<i>A.5.1 Information security policy</i> <i>Objective:</i> To provide management direction and support for information security in accordance with business requirements and relevant laws and regulations
A. 5. 1. 1 信息安全策略文件 控制措施 信息安全策略文件应经过管理层批准，向所有员工和相关外部团体发布和沟通；	A.5.1.1 Information security policy document <i>Control</i> An information security policy document shall be approved by management, and published and communicated to all employees and relevant external parties.
A. 5. 1. 2 信息安全策略评审 控制措施 应按计划的时间间隔或在发生重大的变化时评审策略文件，确保策略的持续性、稳定性、充分性和有效性；	A.5.1.2 Review of the information security policy <i>Control</i> The information security policy shall be reviewed at planned intervals or if significant changes occur to ensure its continuing suitability, adequacy, and effectiveness.

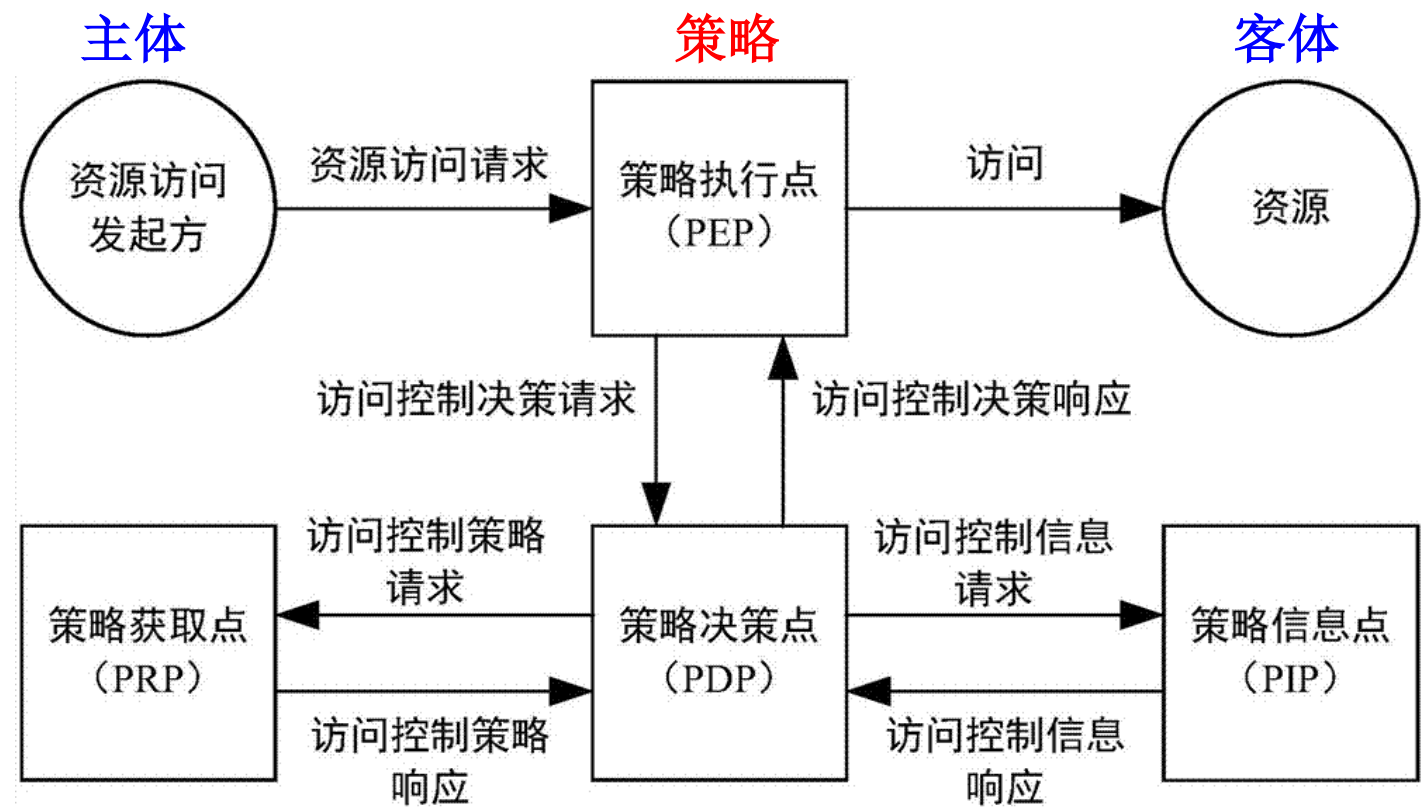
依据ISO 27001制定安全策略的例子

口令控制策略			
发布部门	工程部	生效时间	2013年03月10月
批准人		文件编号	XX-A-04.06
介绍	用户授权是控制信息资源访问者的一种方式。对访问进行控制是任何信息资源所必须的。未经授权的人员访问信息资源可能会引起信息保密性、完整性共和可用性的丢失，导致收入、信誉的损失或经济困难。使用下列两个要素可以鉴别用户，即： ■ 你知道 – 口令识别号（PIN） ■ 你持有 – 智能卡		
目的	该策略的目的是为用户鉴别机制建立创造、分发、保护、终止以及收回的规则。		
适用范围	该策略适用于任何信息资源的使用者。		
术语定义	略		
口令控制策略	■ 所用用户都必须拥有唯一的、专供其个人使用的用户帐号ID（用户ID）； ■ 所有用户不得使用他人的用户进行信息资源的访问； ■ 所有口令，包括初始口令，都必须依据下列规则建立和执行： ◇ 必须定期更改； ◇ 必须符合信息中心规定的最小长度； ◇ 必须是字母、数字和字符的组合； ◇ 必须不能是可以轻易联想到的帐号所有者的特性：用户名、绰号、亲属的姓名、生日等； ◇ 必须不能用字典中的单词或首字母缩写； ◇ 必须保存历史口令，以防止口令的重复使用。 ■ 用户的帐号口令必须不能泄露给任何人； ■ 如果怀疑口令的安全性，应立即进行更改； ■ 管理员不能为了使用信息资源规避口令； ■ 用户不能通过自动登录的方式绕过口令登录程序； ■ 计算机设备如果无人值守必须启动口令保护屏保或注销； ■ 用户在首次登录时必须更改口令。		
惩罚	违背该策略可能导致：员工以及临时工被解雇、合同方或顾问的雇佣关系终止、实习人员和志愿者失去继续工作的机会、学生被开除；另外， 这些人员还可能遭受信息资源访问权以及公民权的损失，甚至遭到法律起诉。		
引用标准	ISO/IEC 27001: 2013		

最常用的安全策略

访问控制策略,

访问控制策略



用户/用户组为主体的例子

计算机管理

文件(F) 操作(A) 查看(V) 帮助(H)

计算机管理(本地)

- 系统工具
 - 任务计划程序
 - 事件查看器
 - 共享文件夹
 - 本地用户和组
 - 用户
 - 组
 - 性能
 - 设备管理器
- 存储
 - 磁盘管理
- 服务和应用程序
 - 服务
 - WMI 控件

名称	全名	描述
Administrator		管理计算机(域)的内置帐户
DefaultAcco...		系统管理的用户帐户。
Guest		供来宾访问计算机或访问域的内...
WDAGUtilit...		Windows Defender 应用...
yajia	Yajian ZHOU	

C:\cmd.exe>compmgmt.msc

计算机管理

文件(F) 操作(A) 查看(V) 帮助(H)

计算机管理(本地)

- 系统工具
 - 任务计划程序
 - 事件查看器
 - 共享文件夹
 - 本地用户和组
 - 用户
 - 组
 - 性能
 - 设备管理器
- 存储
 - 磁盘管理
- 服务和应用程序
 - 服务
 - WMI 控件

名称	描述
Access Control Assist...	此组的成员可以远程查询此计算...
Administrators	管理员对计算机/域有不受限制的...
Backup Operators	备份操作员为了备份或还原文件...
Cryptographic Operat...	授权成员执行加密操作。
Device Owners	此组的成员可以更改系统范围内...
Distributed COM Users	成员允许启动、激活和使用此计...
Event Log Readers	此组的成员可以从本地计算机中...
Guests	按默认值, 来宾跟用户组的成员...
Hyper-V Administrat...	此组的成员拥有对 Hyper-V 所有...
IIS_IUSRS	Internet 信息服务使用的内置组。
Network Configuratio...	此组中的成员有部分管理权限来...
Performance Log Users	该组中的成员可以计划进行性能...
Performance Monitor...	此组的成员可以从本地和远程访...
Power Users	包括高级用户以向下兼容, 高级...
Remote Desktop Users	此组中的成员被授予远程登录的...
Remote Managemen...	此组的成员可以通过管理协议(例...
Replicator	支持域中的文件复制
System Managed Acc...	此组的成员由系统管理。
Users	防止用户进行有意或无意的系统...

进程作为主体的例子

任务管理器						
文件(F) 选项(O) 查看(V)						
进程 性能 应用历史记录 启动 用户 详细信息 服务						
名称	PID	状态	用户名	CPU	内存(活动的...	UAC 虚拟化
AGSService.exe	4672	正在运行	SYSTEM	00	4,752 K	不允许
AlibabaProtect.exe	4596	正在运行	SYSTEM	00		
ApplicationFrameH...	19944	正在运行	yajia	00	11,872 K	已禁用
AppVShNotify.exe	15724	正在运行	SYSTEM	00	1	允许
AppVShNotify.exe	11544	正在运行	yajia	00	1,464 K	已禁用
AsusAppService.exe	18968	正在运行	SYSTEM	00	4,232 K	不允许
AsusLinkNear.exe	24120	正在运行	SYSTEM	00	2,788 K	不允许
AsusLinkRemote.exe	24004	正在运行	SYSTEM	00	3,124 K	不允许
AsusOptimization.e...	20536	正在运行	SYSTEM	00		
AsusOptimizationSt...	21764	正在运行	yajia	00		
AsusOSD.exe	20740	正在运行	yajia	00	1,812 K	已禁用
AsusSoftwareMana...	20172	正在运行	SYSTEM	00	7,444 K	不允许
AsusSoftwareMana...	27784	正在运行	yajia	00	13,820 K	不允许
AsusSystemAnalysi...	30880	正在运行	SYSTEM	00	3,416 K	不允许
AsusSystemDiagno...	16280	正在运行	SYSTEM	00	1,988 K	不允许
audiodg.exe	25924	正在运行	LOCAL SE...	00	63,400 K	允许
backgroundTaskHo...	13184	已挂起	yajia	00	0 K	已禁用
CAJSHost.exe	4608	正在运行	SYSTEM	00	972 K	不允许
CEBMgrService.exe	4664	正在运行	SYSTEM	00		允许
certd_l3000_CEB.exe	14648	正在运行	yajia	00		禁用
chrome.exe	15916	正在运行	yajia	00	14	禁用
chrome.exe	16056	正在运行	yajia	00	1,476 K	已禁用
chrome.exe	15368	正在运行	yajia	00	432,008 K	已禁用

C:\cmd.exe>taskmgr.exe

访问控制策略的描述：访问控制矩阵

按列看是访问控制表内容

目标 用户	目标x	目标y	目标z
用户a	R、W、Own		R、W、Own
用户b		R、W、Own	
用户c	R	R、W	
用户d	R	R、W	

按行看是访问能力表内容

自主访问控制 vs. 强制访问控制

对客体的访问权限到底由谁授予?

自主访问控制策略

❖ “自主”

允许系统中信息的拥有者按照自己的意愿去指定谁可以以何种访问模式去访问该客体。

Windows中的访问控制模型

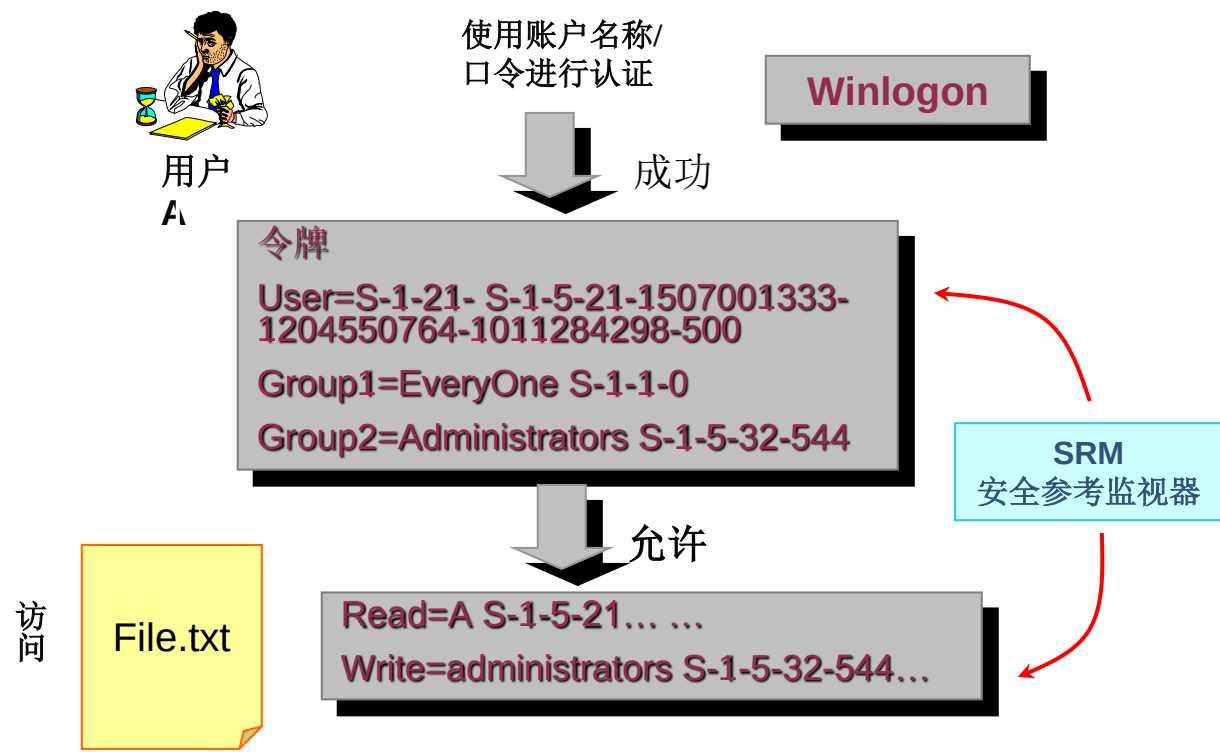
Windows中的访问控制模型是Windows安全性的基础构件。

- 访问控制模型有两个主要的组成部分：访问令牌（Access Token）和安全描述符（Security Descriptor）。它们分别是访问者和被访问者拥有的东西。



通过访问令牌和安全描述符的内容，Windows可以确定持有令牌的访问者能否访问持有安全描述符的对象。

自主访问控制策略实例（Windows Paradigm）

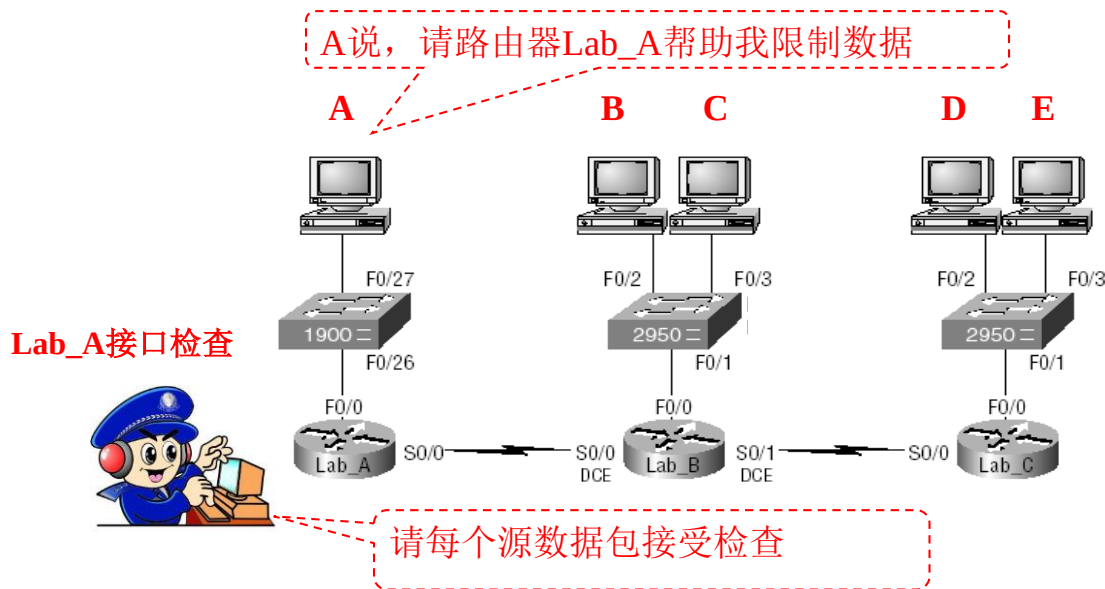


典型的DAC：访问控制列表



访问控制列表

访问控制列表是一系列允许或拒绝数据的指令的集合。



◆ ACL具有灵活的数据流过滤和控制能力

例如，网络管理员可能允许用户访问Internet，而不允许外部的用户登录到局域网中。

访问控制列表的分类



标准ACL

只使用数据包的源地址作为测试条件。所有决定是基于源IP地址的。

Protocol	Range
IP	1-99
Extended IP	100-199
AppleTalk	600-699
IPX	800-899
Extended IPX	900-999
IPX Service Advertising Protocol	1000-1099



扩展ACL

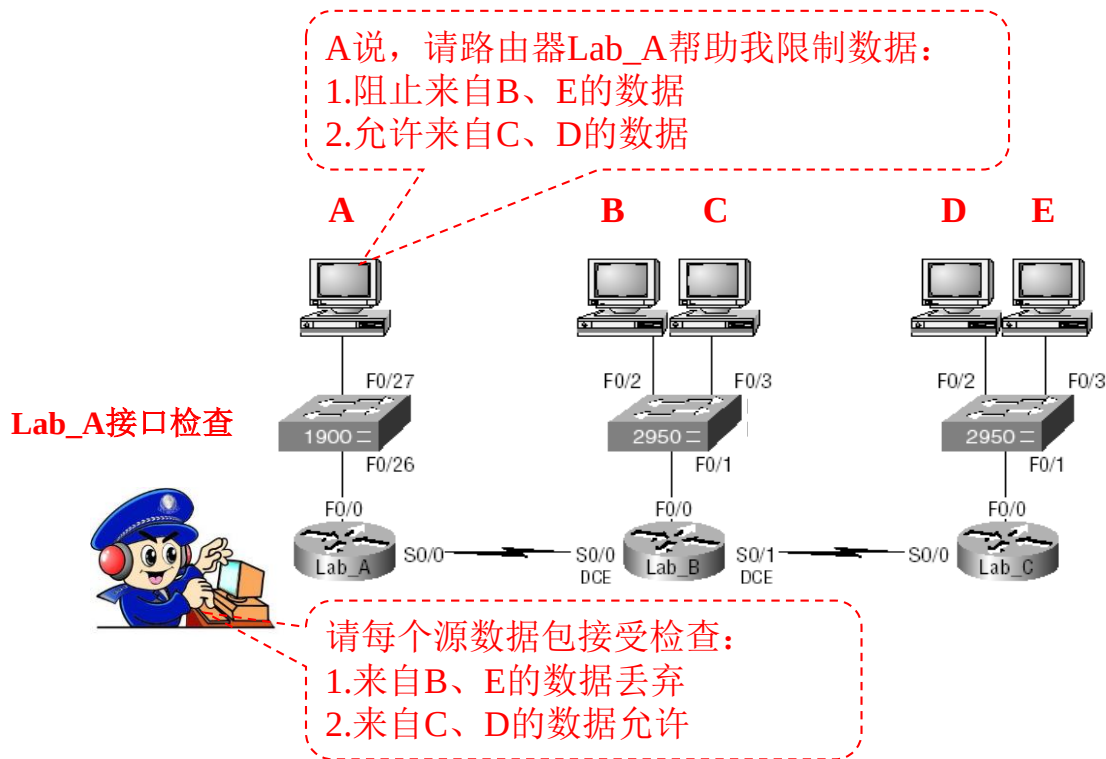
可以测试IP包的第3层和第4层报头中的字段。包括源IP地址、目的IP地址、网络层报头中的协议字段（如，TCP、UDP、ICMP等）以及位于传输层报头中的端口号。



命名ACL

命名ACL以列表名代替列表编号来定义IP访问控制列表，同样包括标准和扩展两种列表，定义过滤的语句与编号方式中相似。

标准列表——基于源地址



- 标准访问列表，通过使用数据包的源IP地址过滤流量。
- 一般用号码区别访问列表类型可以使用访问列表号1~99或1300~1999创建标准的访问列表

创建标准ACL

❖ 创建ACL

```
Router(config)#access-list access-list-number  
{ permit | deny } source [ source-wildcard ]
```

允许数据包通过

拒绝数据包通

标准访问列表的创建根据 “动作” + “源地址”，即允许谁、拒绝谁的方法来创建

❖ 删除ACL

```
Router(config)# no access-list access-list-number
```

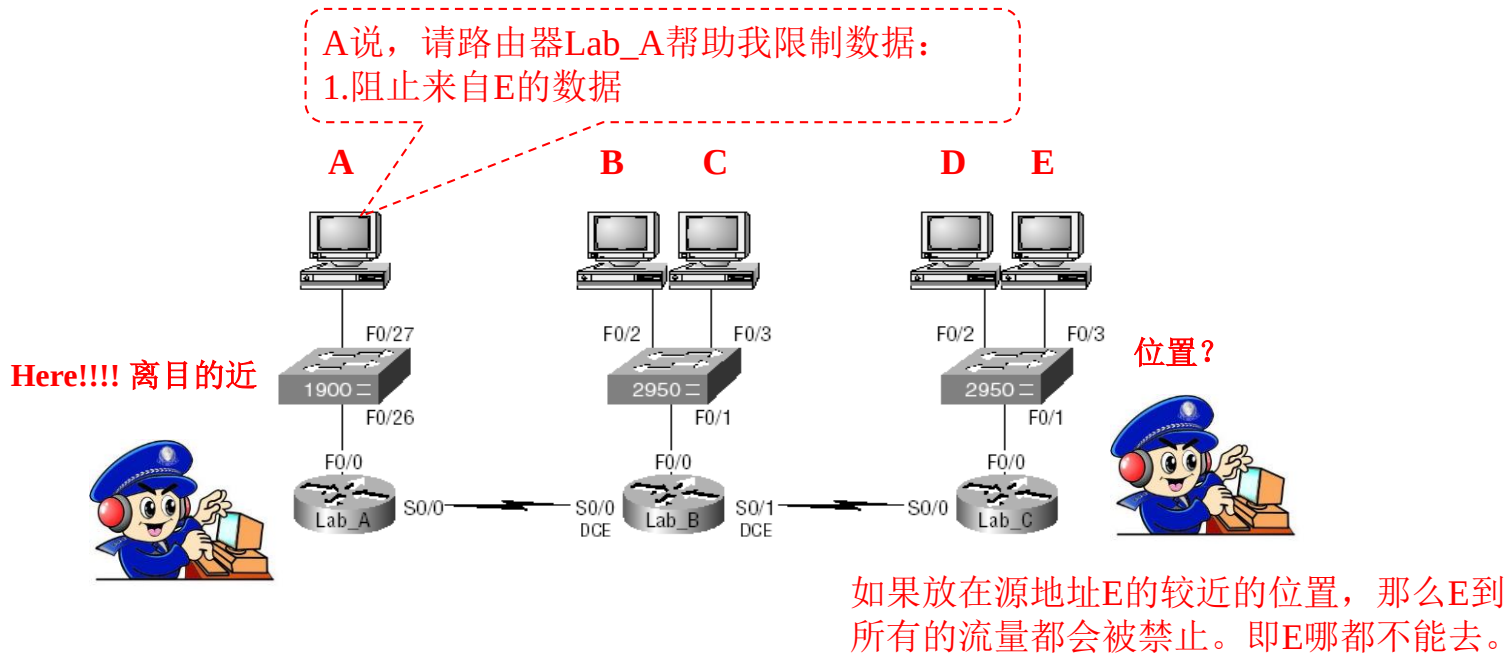
创建标准ACL实例

```
Router(config)# access-list 1 permit 192.168.1.0 0.0.0.255
```

```
Router(config)# access-list 1 permit 192.168.2.2 0.0.0.0
```

允许192.168.1.0/24和主机192.168.2.2的流量通过

标准列表——靠近目的地址



扩展列表——基于源地址、目的地址、协议、端口

❖ 访问控制列表（ACL）

- 读取第三层、第四层包头信息
- 根据预先定义好的规则对包进行过滤



扩展访问列表具有在控制流量时做更细粒度决定的能力。

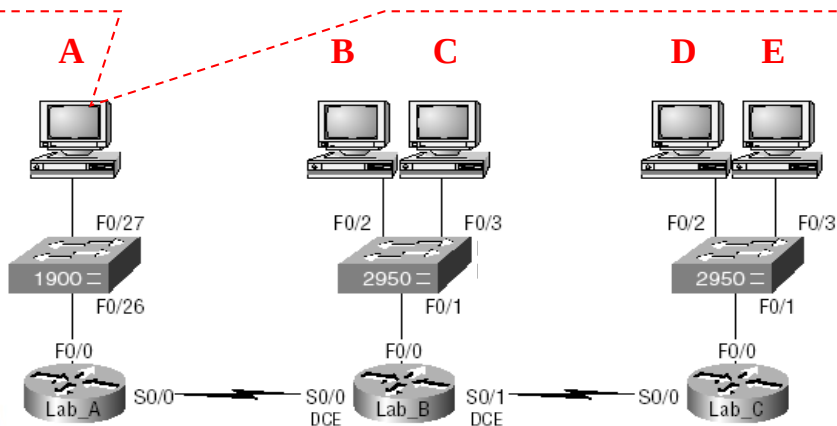
扩展ACL的ID号为100～199 或2000～2699

扩展列表——基于源地址、目的地址、协议、端口

A说，请路由器Lab_A帮助我限制数据：

- 1.阻止来自B、E的FTP数据，但允许来自B、E的HTTP数据
- 2.允许来自C、D的FTP数据，阻止来自C、D的Telnet数据

Lab_A接口检查



扩展ACL的创建命令

Lab_A(config)#access-list ID号 协议 源地址 目的地址 操作符 端口/服务类型

100
~
199

或

2000
~
2699

源地址是从哪来，目的地址表示到哪去

IP
ICMP
TCP
UDP
及路由协议

注：若过滤应用层数据，则此处必须为TCP
UDP

（可省，若操作符省略则其后端口亦可省）

Eq
Gt
Lt
Neq
Established
Log

（可用端口号亦可用指定的名称）

ftp 21
ftp-data 20 21
Smtpt 25
telnet 23
www 80
等等

Examples: 扩展ACL

1. **Lab_A(config)#access-list 110 deny tcp any host 172.16.30.2 eq www**

含义：拒绝任何IP地址通过TCP协议访问主机172.16.30.2的www服务。隐含的意思是主机可以访问172.16.30.2的其它服务，限制更为细致。

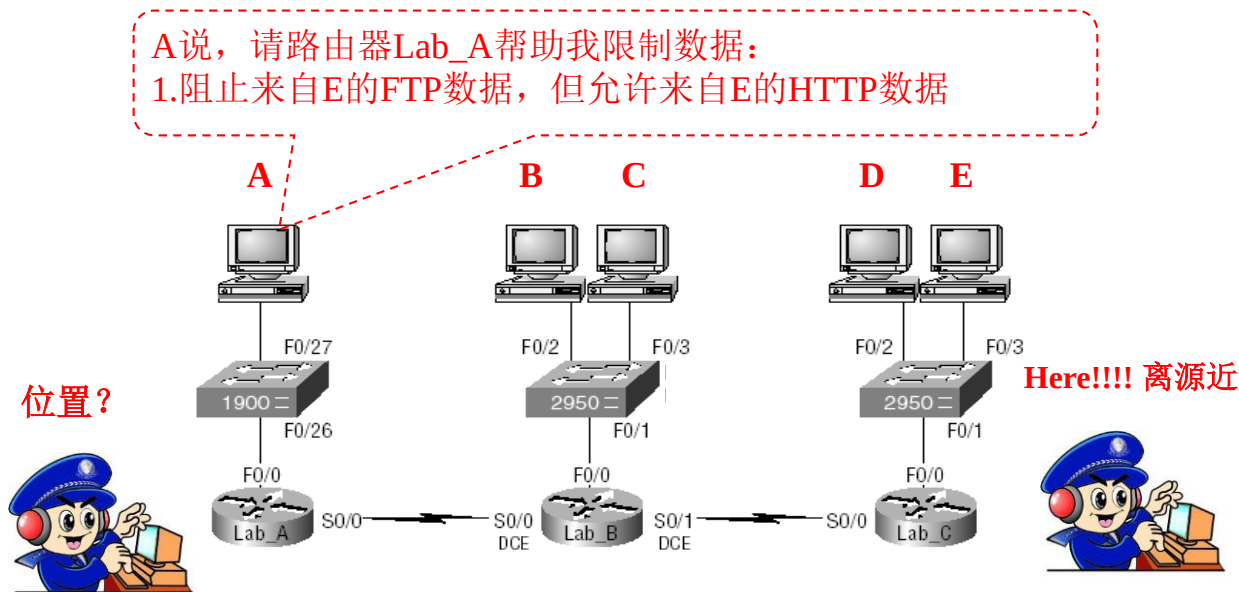
2. **Lab_A(config)#access-list 110 permit tcp 192.168.10.0 0.0.0.255 host 172.16.30.2 eq 23 log**

含义：允许网段192.168.10.0 255.255.255.0通过TCP协议访问主机172.16.30.2的23端口的服务即Telnet服务，且记录访问日志。

3. **Lab_A(config)#access-list 110 permit ip any any**

含义：允许所有使用IP协议的IP访问其它所有IP，即允许所有。

扩展列表的放置——靠近源地址



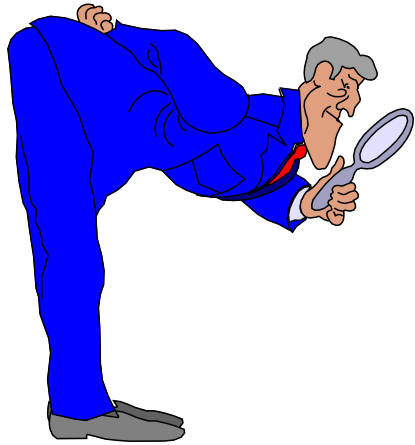
如果放在离目的地址A较近的位置，那么E到A的FTP流量将会穿过整个网络，在到达目的地的时候却被告知不可以到达，浪费网络带宽。即E的FTP流量白传播一趟

设置访问控制列表面临的一个问题

如果要屏蔽来自192.168.0.0/24~192.168.2.0/24
网段的所有ICMP数据包，怎么设置ACL?



Possible solution 1

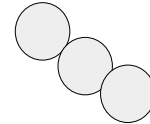


`Router(config)# access-list 10 icmp deny 192.168.0.1`

`Router(config)# access-list 10 icmp deny 192.168.0.2`

`Router(config)# access-list 10 icmp deny 192.168.0.3`

How many totally?



真正让人期待的解决方案

以批处理的方式，自动进行

```
Router(config)# access-list 10 permit any any
```



通配掩码

路由器使用**IP地址**和**通配掩码**（wildcard-mask）一起来分辨匹配的地址范围，它跟子网掩码刚好相反。

- 它不像子网掩码告诉路由器IP地址的哪一位属于网络号一样，通配符掩码告诉路由器为了判断出匹配，它需要检查IP地址中的多少位。
- 有了通配掩码，可以只使用两个32位的号码来确定IP地址的范围，**这是十分方便的！**

如果没有掩码的话，不得不对每个匹配的IP地址加入一个单独的ACL语句。这将造成很多额外的输入和路由器大量额外的处理过程。**所以地址掩码相当有用！**

通配掩码

- 通配掩码（wildcard mask）是分成4字节的32bit数
- 通配掩码与IP地址位位配对，相应位为0/1，用于表示如何对待IP地址中的相应位

通配掩码某位是0

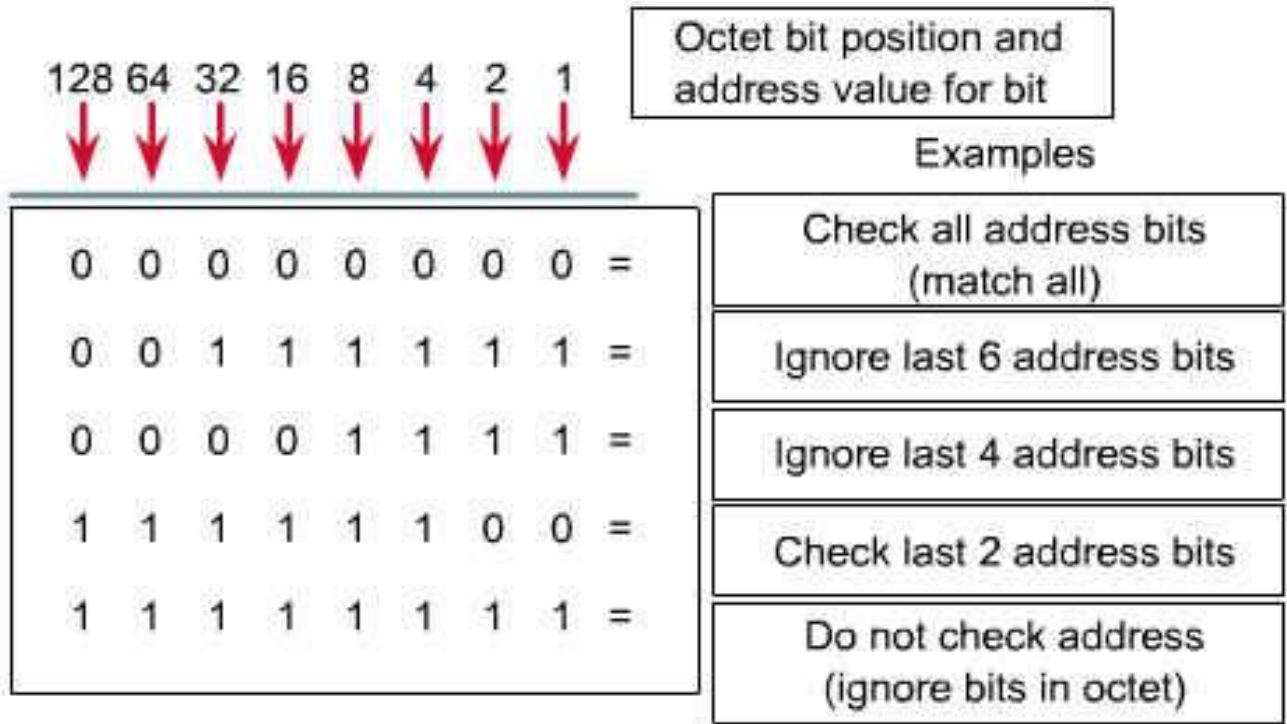
表示检查相应bit位的值

通配掩码某位是1

表示不检查（忽略）相应位的值



通配掩码的工作原理

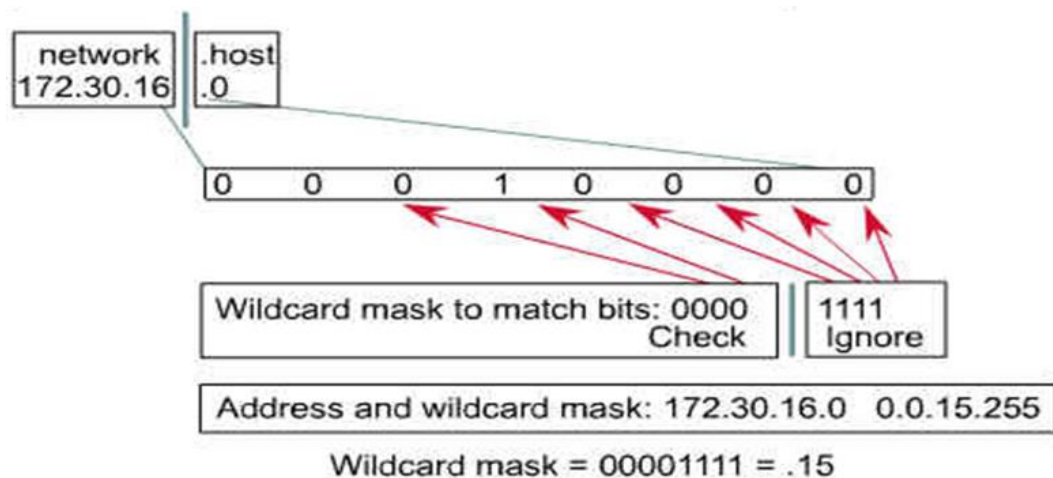


0	0	0	0	0	0	0	0	=
0	0	1	1	1	1	1	1	=
0	0	0	0	1	1	1	1	=
1	1	1	1	1	1	0	0	=
1	1	1	1	1	1	1	1	=

- Check all address bits (match all)
- Ignore last 6 address bits
- Ignore last 4 address bits
- Check last 2 address bits
- Do not check address (ignore bits in octet)

通配掩码举例

- 假设一个B类地址，有16位子网地址。想使用通配掩码，允许所有来自于网络172.30.16.0～172.30.31.0的数据报访问。



- 首先，检查前面两个字节（171.30），通配掩码中的前两个字节位全为0。
- 由于没有兴趣检查主机地址，通配掩码的最后一个字节位全为1。

any——通配符特殊应用

□ 在路由器中谈到默认路由时使用的地址是：

ip route 0.0.0.0 0.0.0.0 192.168.0.2

- 其中0.0.0.0 0.0.0.0 表示任意网络地址，其子网掩码0.0.0.0表示不对任何地址做匹配
- 在ACL中如果要表示任意地址，也可用此种形式。不过通配符因为 — 0.0.0.0 = 255.255.255.255。即ACL中0.0.0.0 255.255.255.255表示任意地址。但有时书写较为麻烦，可以用单词 any 替代
- 即any 与0.0.0.0 255.255.255.255均表示任意地址
 - ➔ Router(config)# access-list 1 permit 0.0.0.0 255.255.255.255
 - 等价于
 - ➔ Router(config)# access-list 1 permit any

host ——通配符特殊应用

- 同样在路由器章节中，设置环回接口地址时，使用255.255.255.255的子网掩码，我们称此为主机掩码，表示此网络中只有一个给主机使用的地址。如，192.168.0.1 255.255.255.255。
- ACL中的主机地址可以为 192.168.0.1 0.0.0.0
- 同样，可以简化输入使用单词 host替代。注：在使用主机地址的时候单词 host也可省略。即

→ Router(config)# access-list 1 permit 171.30.16.29 0.0.0.0

等价于

Router(config)# access-list 1 permit host 171.30.16.29

自主访问控制策略

❖ 自主访问控制的优点

- 访问模式设定灵活。
 - 读；写；执行；“每隔一周的周五可以读”；“读完文件x后才能读此文件”等等
- 具有较好的适应性，常用于商用OS和应用中

❖ 自主访问控制的缺点

- 不能防范木马和某些形式的恶意代码。
- 思考：一个用户的程序中隐藏了木马，将会如何？

强制访问控制



强制访问控制策略

❖ 经典场景：军事机密及其管理

- 无密级；保密；机密；绝密。

❖ 强制访问控制，基于上述原型而来

- 主体/客体：贴上标签
- 引用监视器：比较标签，决定是否许可

❖ 效果：保证完整性或机密性

强制访问控制策略



在强制访问控制系统中，所有主体（用户，进程）和客体（文件，数据）都被分配了安全标签，安全标签标识一个安全等级。

- 主体（用户，进程）被分配一个安全等级
- 客体（文件，数据）也被分配一个安全等级
- 访问控制执行时对主体和客体的安全级别进行比较

Bell-LaPadula模型

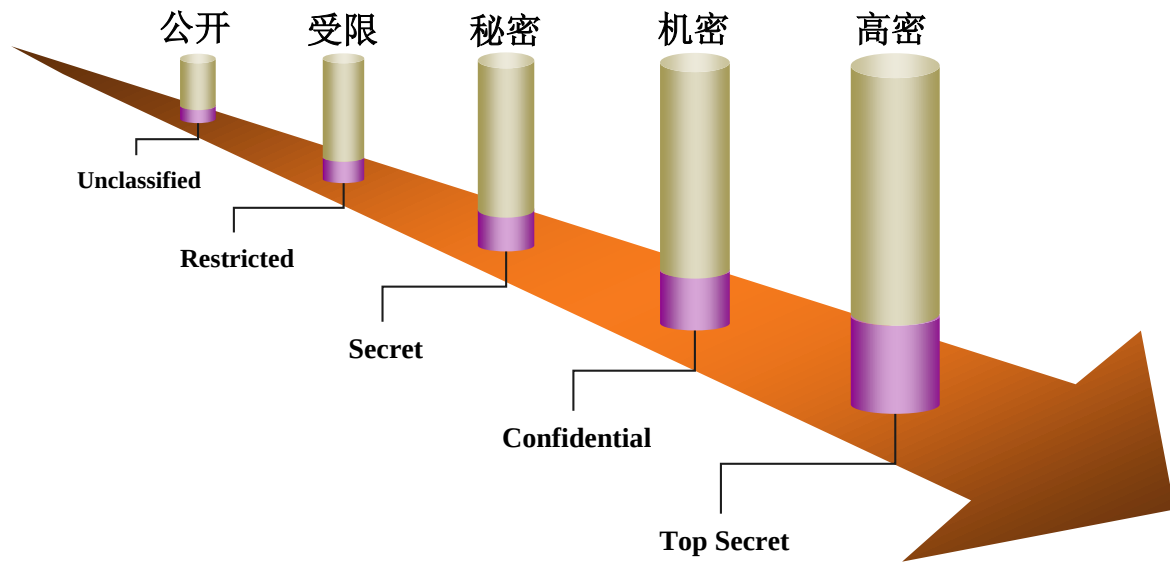
Bell-LaPadula保密性模型是第一个能够提供分级别数据机密性保障的安全策略模型（多级安全）。

- 1973年，David Bell和Len LaPadula提出了第一个正式的安全模型，该模型基于强制访问控制系统，以敏感度来划分资源的安全级别。将数据划分为多安全级别与敏感度的系统（称之为多级安全系统）。
- Bell-LaPadula（BLP）安全模型对主体和客体按照强制访问控制系统的思想进行分类，这种分类方法一般应用于军事用途。

[1] Bell D E, LaPadula J L. Secure computer systems: mathematical foundations, M74-244[R]. Bedford: The MITRE Corporation, 1973.

[2]刘波，陈曙晖，邓劲生. Bell-LaPadula模型研究综述[J]. 计算机应用研究，2013，30(3): 656-660.

Bell-LaPadula模型



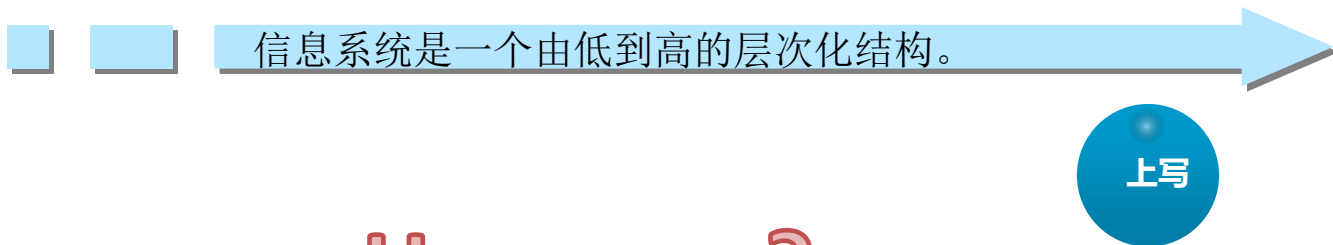
❖ 数据和用户被划分为五个安全等级

Bell-LaPadula模型

BLP 保密模型基于两种规则来保障数据的机密度与敏感度：

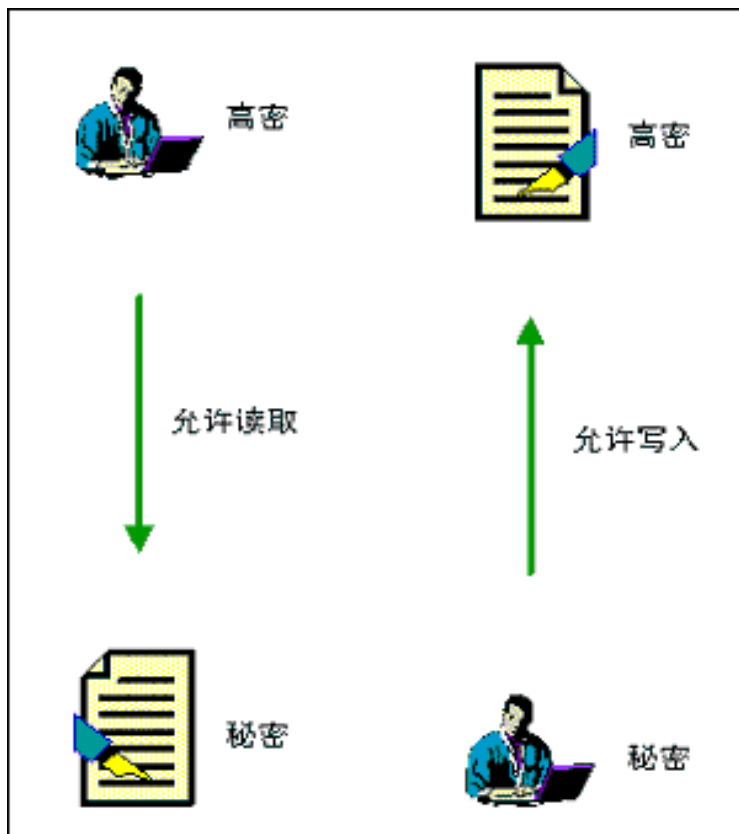
- 不上读（NRU）——主体不可读安全级别高于它的数据
- 不下写（NWD）——主体不可写安全级别低于它的数据

BLP模型允许用户读取安全级别比他低的资源；相反地，写入对象的安全级别只能高于用户级别。



However?

Bell-LaPadula模型

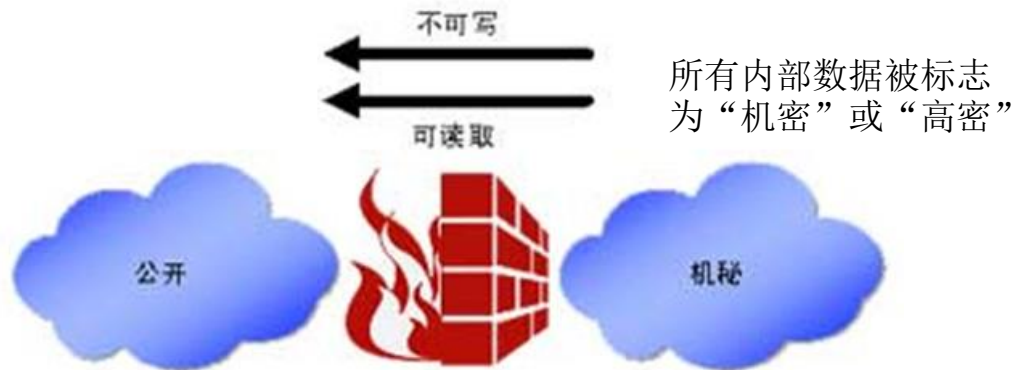


- 安全级别为“高密”的用户在访问安全级别为“秘密”的文档时，将能够成功读取该文件，但不能写入；
- 安全级别为“秘密”的用户不能访问安全级别为“高密”的文档，但能够写入。
- 这样，文档的保密性就得到了保障。

防火墙所实现的单向访问机制

防火墙所实现的单向访问机制不允许敏感数据从内部网络（例如，其安全级别为“机密”）流向Internet（安全级别为“公开”）。

- 防火墙提供“不上读”功能来阻止Internet对内部网络的访问；
- 提供“不下写”功能来限制进入内部的数据流只能经由由内向外发起的连接流入（例如，允许HTTP的“GET”操作而拒绝“POST”操作，或阻止任何外发的邮件）。



BIBA完整性模型

- 20世纪70年代，Ken Biba提出了BIBA访问控制模型，该模型对数据提供了分级别的完整性保证，类似于BLP保密性模型，BIBA模型也使用强制访问控制系统。
- BIBA完整性模型对主体和客体按照强制访问控制系统的思想进行分类，这种分类方法一般应用于军事用途。

BIBA完整性模型

BIBA模型基于两种规则来保障数据的完整性的保密性：

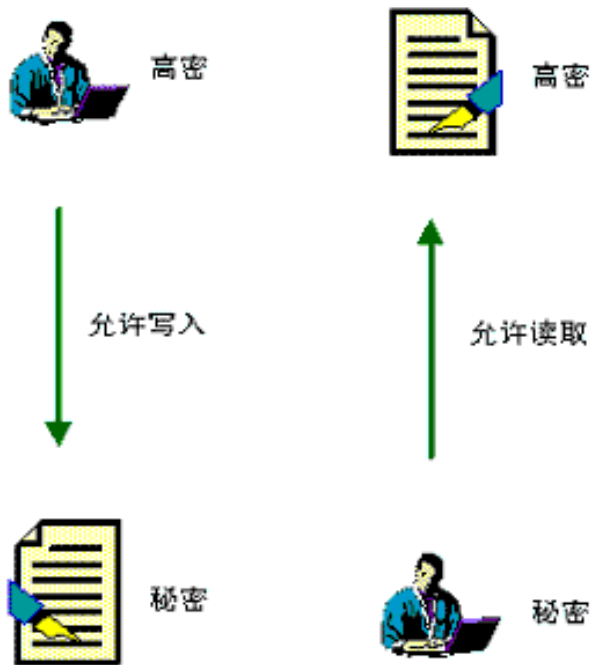
- **不下读 (NRU)** 属性主体不能读取安全级别低于它的数据
- **不上写 (NWD)** 属性主体不能写入安全级别高于它的数据

从这两个属性来看，BIBA与BLP模型的两个属性是相反的：

- BLP模型提供保密性；
- BIBA模型对于数据的完整性提供保障。

BIBA模型并没有被用来设计安全操作系统，但大多数完整性保障机制都基于**BIBA**模型的两个基本属性构建。

BIBA完整性模型



因此，只有用户的安全级别高于资源的安全级别时可对资源进行写操作。
相反地，只有用户的安全级别低于资源的安全级别时可读取该资源。

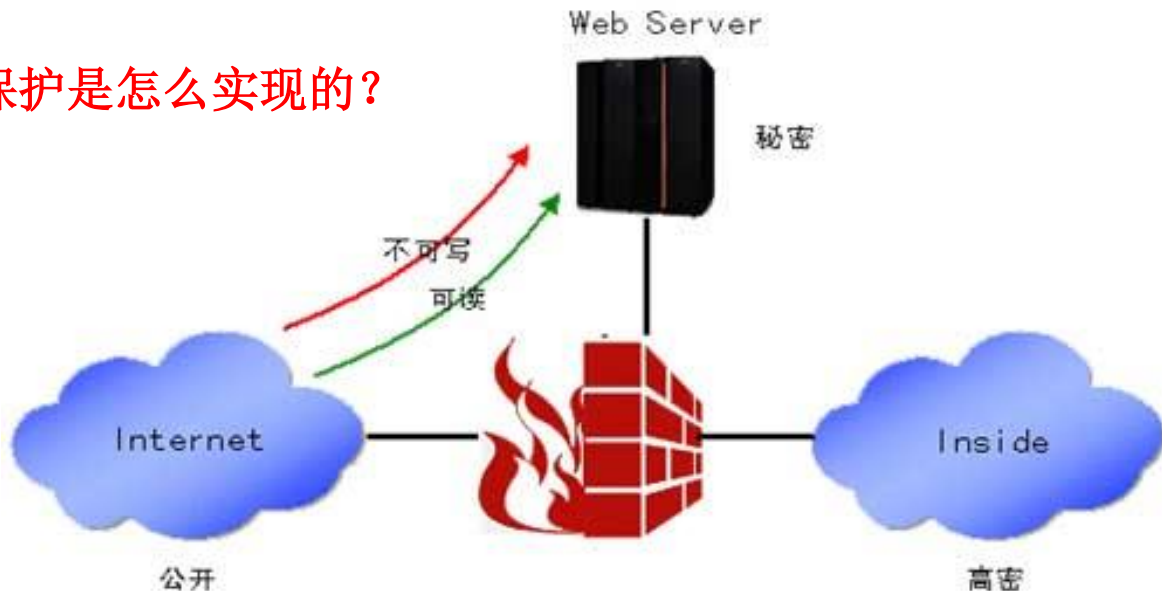
上读

下写

信息在系统中只能自上而下进行流动。

Biba完整性模型的应用1

对信息完整性的保护是怎么实现的？



Internet上用户的安全级别为“公开”，依照**BIBA**模型，Web服务器上数据的完整性将得到保障，**Internet**上的用户只能读取服务器上的数据而不能更改它。因此，任何**POST**操作将被拒绝。

Chinese Wall模型

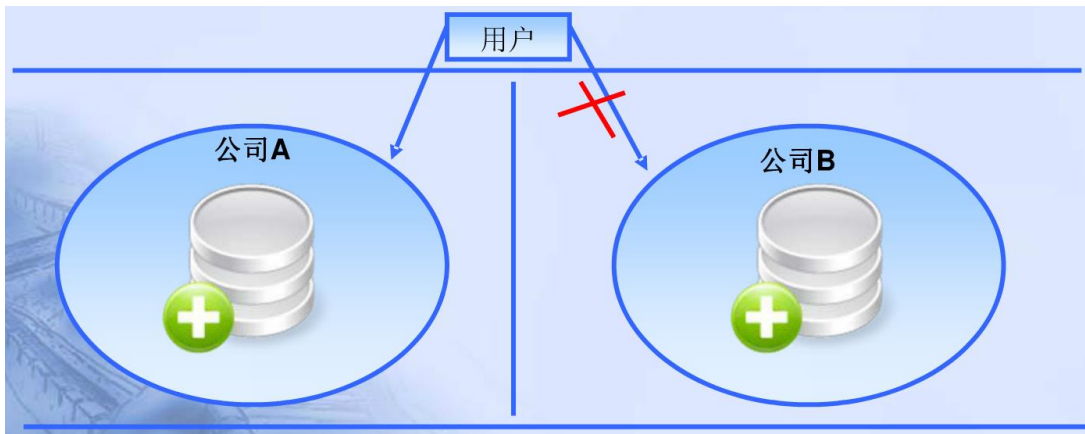
Chinese Wall模型应用在多边安全系统中（也就是多个组织间的访问控制系统），目标主要就是防止利益冲突的发生

Chinese Wall模型最初是为投资银行设计的，主要关注商业利益问题，使用范围有限，但也可应用在其它相似的场所。

在投资银行中，一个银行会同时拥有多个互为竞争者的客户，一个银行家可能为一个客户工作，但他可以访问所有客户的信息。因此，应当制止该银行家访问其它客户的数据。

Chinese Wall模型

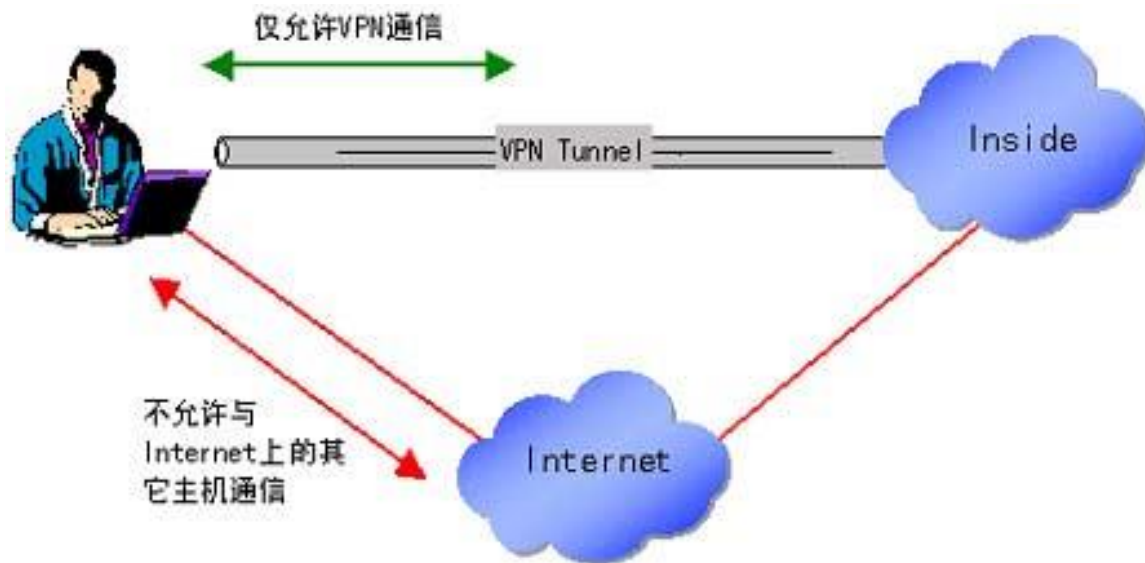
Chinese Wall模型的主要功能是防止用户访问被认为是存在利益冲突的数据。



Chinese Wall安全策略的基础是客户访问的信息不会与目前他们可支配的信息产生冲突

信息被分组成若干利益冲突的类，一个人在每个类中至多允许访问一组信息

Chinese Wall安全模型的应用：远程访问VPN



单向会话只发生在有限的时间内，本安全模型的核心在于：用户选择与其中一方进行通信，则放弃了与另一方会话的权利。

强制访问控制策略

❖ 最显著的特征：全局性和永久性

➤ 无论何时何地，主体和客体的标签是不会改变的。

➤ **全局性**：对特定的信息，从任何地方访问，它的敏感级别相同

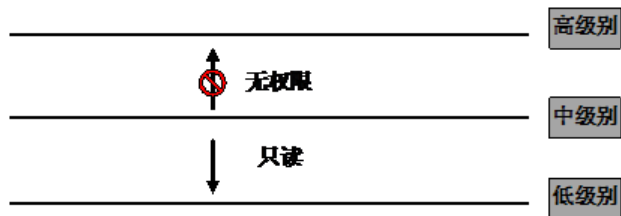
➤ **永久性**：对特定的信息，在任何时间访问，它的敏感级别相同

➤ 上述特征在多级安全体系中称为“**宁静性原则**”（tranquility）

❖ 一旦不满足该原则，无法从根本上防备木马和恶意代码

思考题

是否可以设计一种基于Bell-LaPadula模型和BIBA模型的混合模型，从而既能保护数据的机密性，又能保证其完整性？



SSR模型和BLP、BIBA模型一样，通过安全标签的方式实现用户级别的强制访问控制，所不同的是标签安全中级别和级别的访问控制模型方案。**SSR安全模型侧重于更强的完整性和保密性要求同时满足。**

此安全模型由浪潮嘉信公司提出并应用于其服务器安全加固系统中。

SSR的访问控制为：

- 允许同级别的主体对客体享有所有权限；
- 高级别主体对低级别客体有只读权限；
- 低级别主体对高于自己级别的客体没有任何权限。

Summary of The Class



□ 安全需求

- “知己知彼”
- 在信息系统的用户和开发人员之间建立一套理解和沟通的“桥梁”
- 如何获取实际信息系统的安全需求，如何描述安全需求

□ 安全策略

- 描述信息资产如何被保护的一个计划
- 如何描述
- 访问控制策略 & 访问支持策略